Web Application Security Assessment

Time Used

Approximately **2–3 hours**

1. Introduction

The purpose of this project was to perform a basic security assessment of the web application **demo.testfire.net**.

I used Kali Linux and Firefox to identify the web technologies, available services, login and input areas, session cookie settings, security headers, and other publicly accessible application features.

No brute-force attacks, exploitation, or denial-of-service testing was performed.

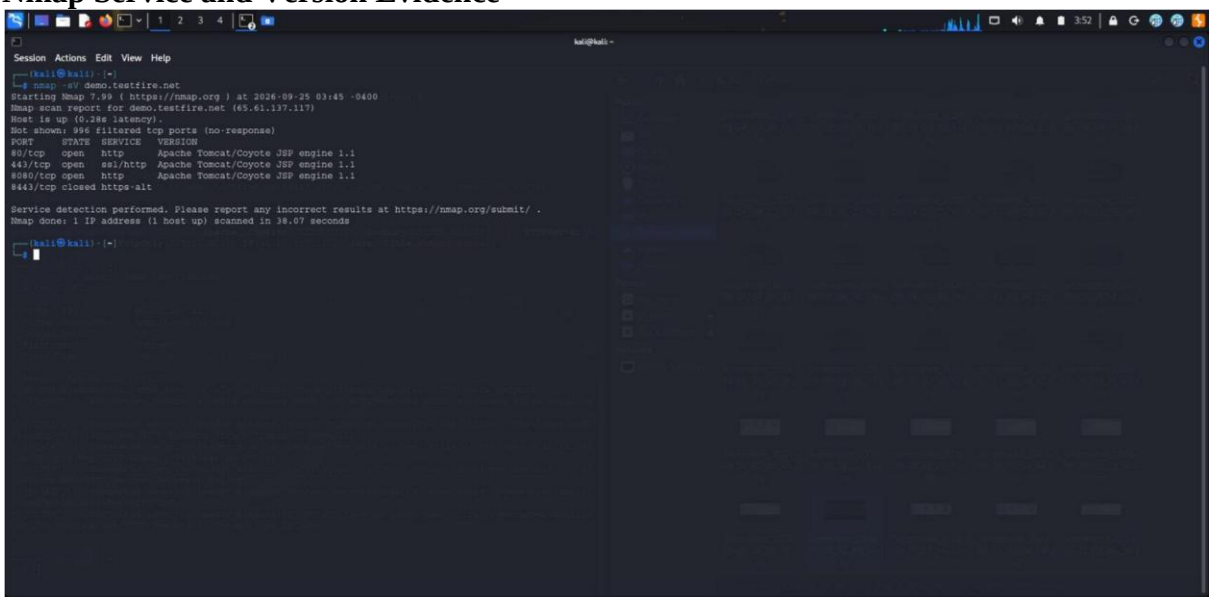
2. Reconnaissance

The target was identified as:

- Domain: `demo.testfire.net`
- IP Address: `65.61.137.117`
- Web Server: Apache-Coyote/1.1
- Application Technology: Java
- Application Title: Altoro Mutual

Nmap identified HTTP/HTTPS services on ports **80, 443, and 8080**. Port 8443 was also reported by Nmap, but a direct connection test did not succeed.

Nmap Service and Version Evidence



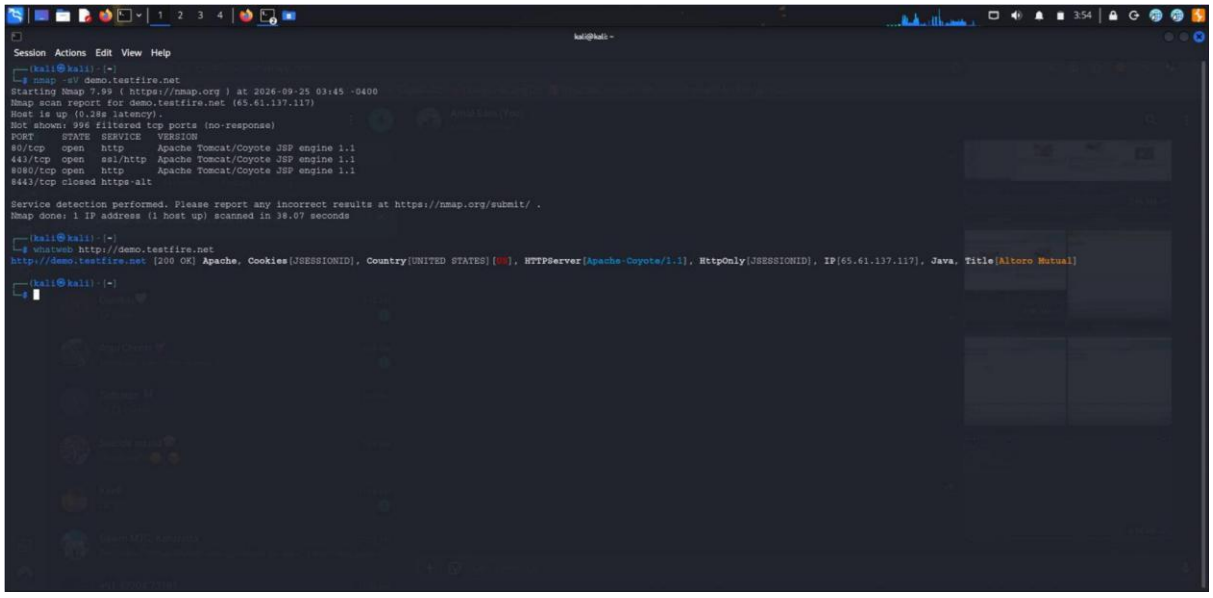
3. Web Technology Identification

WhatWeb was used to identify the technologies used by the website.

The scan identified:

- Apache-Coyote/1.1
- Java
- JSESSIONID cookie
- HttpOnly attribute on the JSESSIONID cookie
- IP address: 65.61.137.117

WhatWeb Evidence



4. Attack Surface Mapping

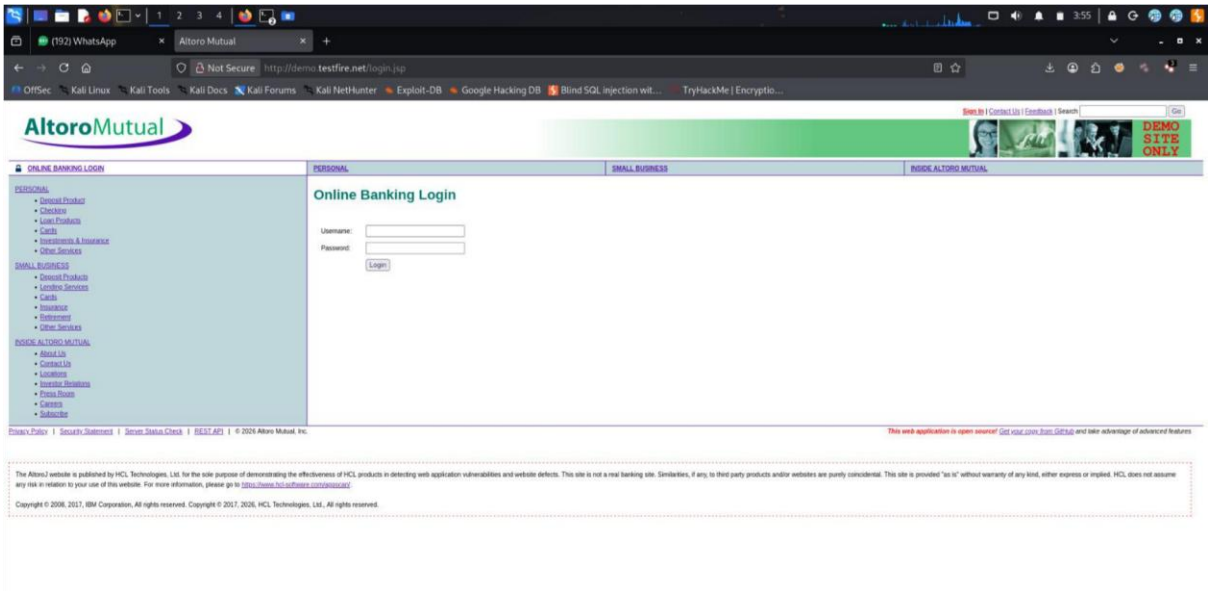
The application contains several publicly accessible areas.

The following pages/features were identified:

- Online Banking Login
- Search
- Feedback
- Contact Us
- Server Status Check
- REST API / Swagger documentation
- Personal Banking
- Small Business
- Other application pages

The login page was reviewed without entering any credentials.

Login Page Evidence



The Feedback and Contact Us pages were also reviewed as part of the attack surface assessment.

5. Expired HTTPS Certificate

The HTTPS connection showed a browser security warning because the certificate had expired.

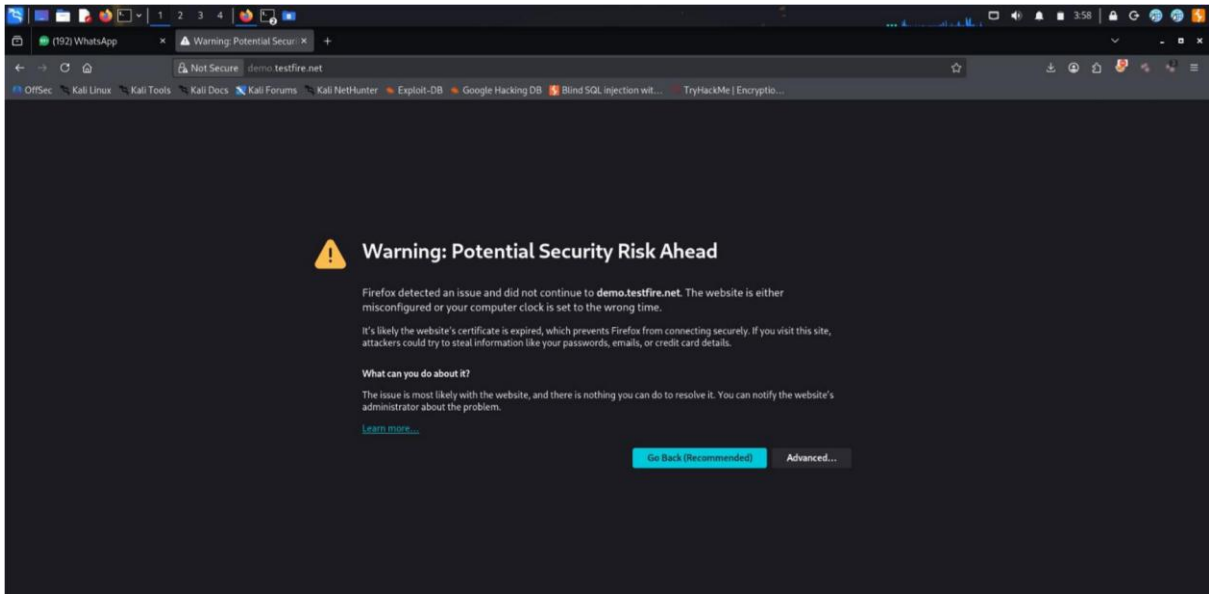
The certificate expiration date shown by Firefox was:

June 21, 2026

The error displayed was:

`SEC_ERROR_EXPIRED_CERTIFICATE`
The same issue was also confirmed using curl.

Expired Certificate Evidence



This can cause browser security warnings and prevents the certificate from being normally trusted.

6. Session Cookie Security

The JSESSIONID cookie was reviewed using Firefox Developer Tools.

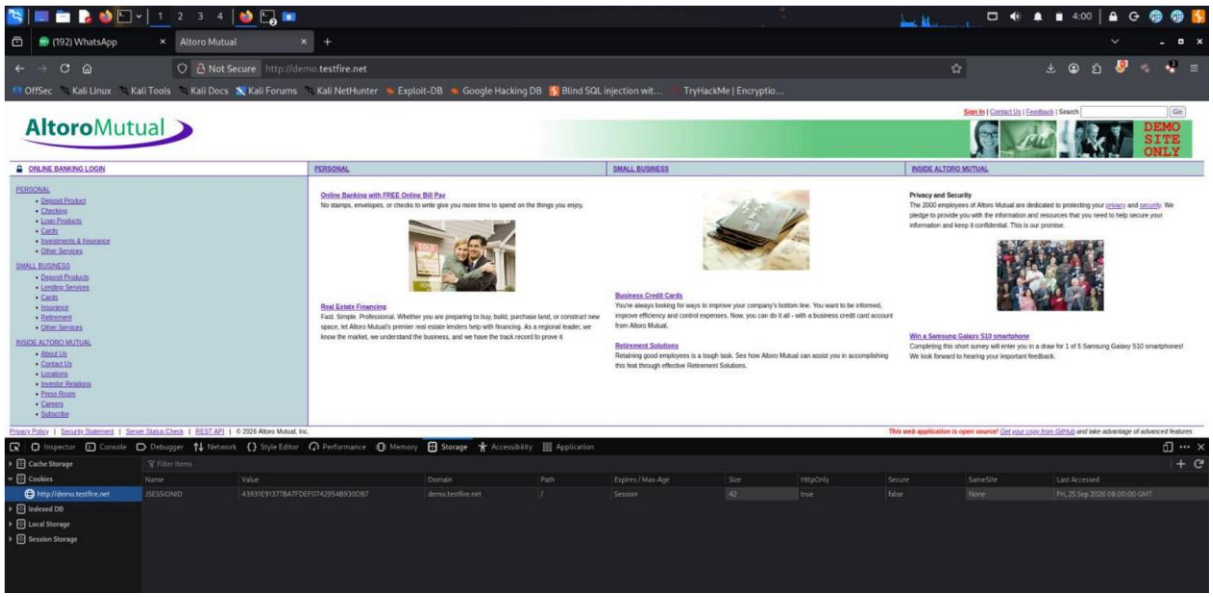
The following values were observed:

- Cookie: JSESSIONID
- Path: `/`
- HttpOnly: `true`
- Secure: `false`
- SameSite: `None`
- Expiry: Session

The important observation was that the **Secure attribute was disabled**.

This means the cookie was not marked to be sent only over HTTPS.

JSESSIONID Cookie Evidence



The actual cookie value was not included in the report.

7. Security Headers

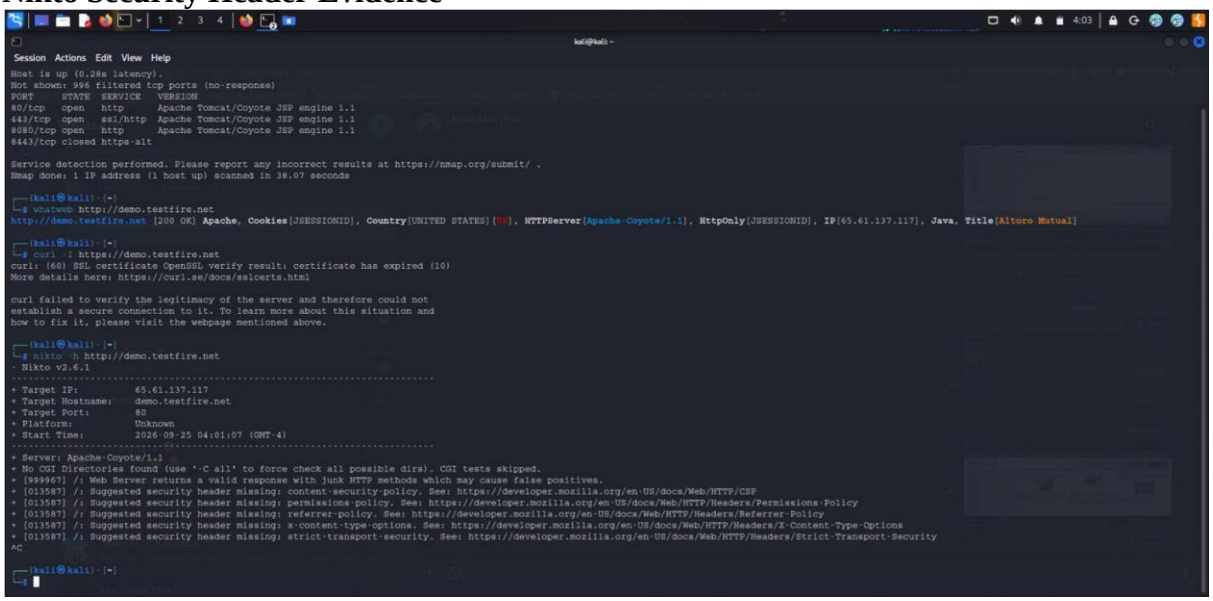
Nikto was used to check the web server for common security headers.

The following headers were reported as missing:

- Strict-Transport-Security
- Permissions-Policy
- Referrer-Policy
- Content-Security-Policy
- X-Content-Type-Options

These observations indicate that some recommended browser security protections were not configured on the tested HTTP response.

Nikto Security Header Evidence



The Nikto result alone does not prove that these missing headers were directly exploitable.

8. Server Information Disclosure

The server response exposed the following server information:

```
Apache-Coyote/1.1
```

This information was observed through Nmap, WhatWeb, and HTTP response headers.

This is mainly an information disclosure issue because it provides details about the server technology to clients.

9. Public REST API Documentation

The application provides publicly accessible Swagger documentation.

The page identified itself as:

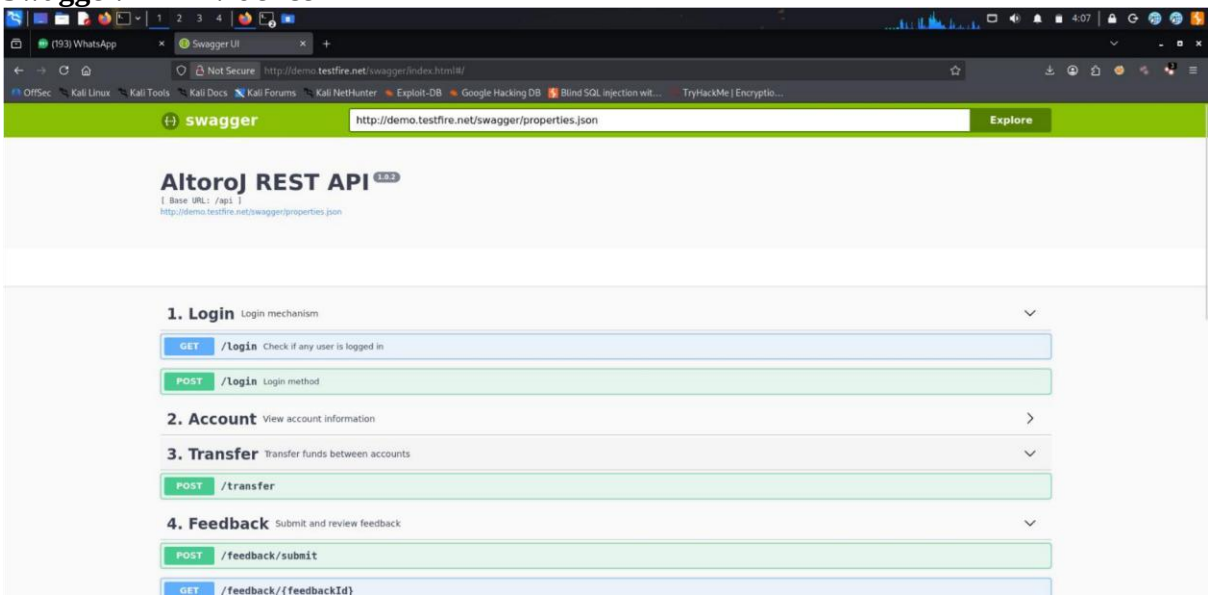
AltoroJ REST API – Version 1.0.2

The documentation included endpoints related to:

- Login
- Account
- Account transactions
- Transfers

No API requests or modifications were performed.

Swagger/API Evidence



The public documentation was treated as an attack-surface observation rather than a confirmed vulnerability.

10. Input Validation Check

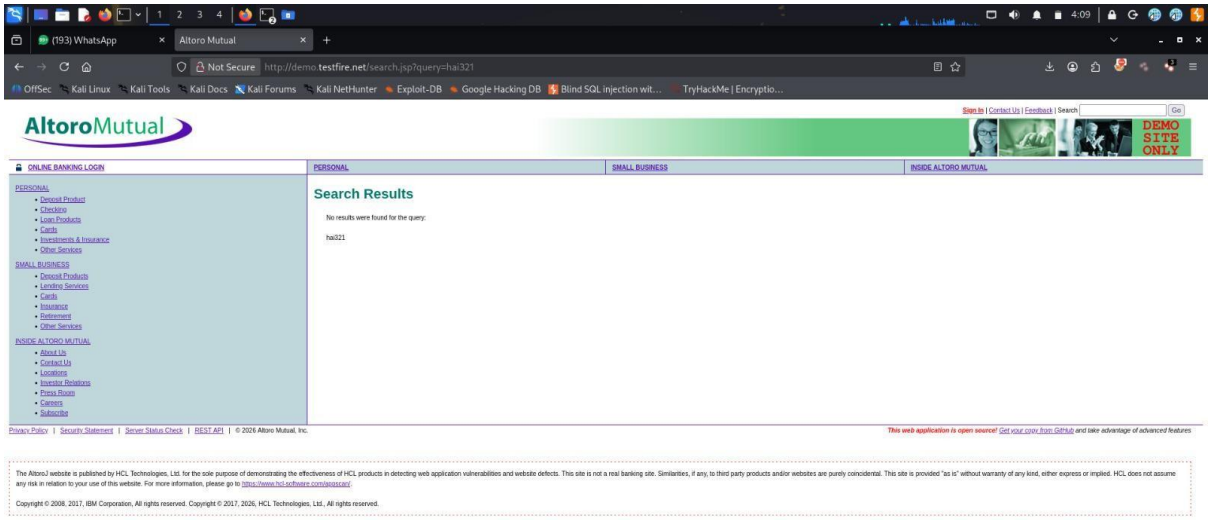
A basic input test was performed using the normal search value: `hai123`

The application processed the input and returned:

“No results were found for the query: hai123”

No error message or abnormal response was observed during this basic test. **Input**

Validation Evidence



No input-validation vulnerability was confirmed from this test.

11. Main Findings

The main findings from the assessment were:

- Target IP: **65.61.137.117**
- Apache-Coyote/1.1 server identified.
- Java-based application identified.
- HTTP services were available on ports 80 and 8080.
- HTTPS certificate was expired.
- JSESSIONID cookie had **Secure=false**.
- Several recommended security headers were reported as missing.
- Server technology information was exposed.
- Swagger/API documentation was publicly accessible.
- Basic search input testing did not show an abnormal response.
- No exploitation, brute force, or DoS testing was performed.

12. Conclusion

The web application assessment identified several security-related observations, mainly the **expired HTTPS certificate, disabled Secure attribute on the JSESSIONID cookie, missing security headers, and exposed server information**.

The application also contains publicly accessible login, feedback, contact, server-status, and API documentation pages.

Based on the tests performed, no confirmed input-validation vulnerability was identified. The assessment was limited to basic reconnaissance and non-destructive security checks, and the findings were based on the evidence collected during the investigation.